

Halden Distribution Ltd. — Active Directory risk: executive summary

Prepared by: Muhammad Ibrahim Akmal, IT (Systems) · **For:** Managing Director and department heads
Date: 2026-10-02 · **Change record:** p03-change-record.md · **Full register:** p03-findings-register.md

Status: assessment not yet completed. This one-pager is written and ready, but the numbers in it will only be filled in from the real assessment run in the isolated lab. Nothing below has been measured yet, and no score or finding is presented as fact (see the note at the end of the page).

The risk in one paragraph

Right now, one careless click is enough to lose the whole company's computer network. Today every workstation at Halden uses the **same local administrator password**, our IT staff use ****one administrator account for everything including email****, several ex-employees and unused accounts still hold the highest level of access, and the passwords that our systems use to talk to each other have not changed in years. If any single laptop is compromised, an attacker already has the keys to every other computer — and ransomware operators do exactly this, because controlling the directory lets them encrypt every machine at once. **These are the settings we are fixing, and here is when.**

What we are doing about it

#	Action	Business effect	Target
1	Give every computer its own rotating local administrator password	One compromised laptop stops being a key to all the others	within 2 weeks
2	Separate administrator accounts: each IT person keeps an ordinary account plus their admin account	An admin's email or browsing can no longer hand over the domain	within 3 weeks
3	Remove ex-employees and unused accounts from the highest access level	Fewer doors left open by accident	immediately
4	Replace old system passwords with automatically managed ones	Passwords copied off the network can no longer be cracked offline	within 4 weeks
5	Switch off outdated protocols still accepted by our servers	Blocks a family of well-known attacks that need no user mistake	audited first, then enforced

What we are not doing, and why

- **We are not measuring a penetration test.** Our tooling maps which permissions could be used and reports weak settings. It does not attempt to break in or crack passwords. That is a deliberate limit, and it is what makes the results safe to share internally.
- **Some items will be accepted rather than fixed** if the fix would disrupt a business system. Any such item will carry a named owner, a written reason and a review date — it will not just be dropped silently.

What we need from the business

Ask	From	Why
Agreement that administrator access is a role, not a right — IT staff will hold two accounts	Managing Director	It works only if people use the separate admin account every time
Department heads to confirm who still needs elevated access	Department heads	The business owns access decisions; IT implements them
One short window out of hours for the network protocol changes	Managing Director	These changes are audited first, but enforcement should still happen when nobody is working
A decision on any item we recommend accepting rather than fixing	Managing Director	Residual risk needs a business owner, not an IT opinion

How progress will be reported

A one-page summary each month: what was fixed, what is still open, what was accepted and why, and one headline measure — the directory's overall risk score, before and after, from the same tool each time so the comparison is fair.

Honesty note for the file. Halden Distribution Ltd. is a fictional company used for a home-lab portfolio project, and the weaknesses described here were deliberately created in an isolated lab so that this assessment has something real to find. The technical work, the tooling and the measurements are real; the company, the staff and the "attack" are not. This page carries no measured figure yet because the assessment has not been run — when it is, the figures will be inserted from the evidence files listed in the project's `README.md`.